

1: Firewall (RO)

This slide deck introduces the fundamental concepts, roles, architectures and types of firewalls in network security. Below is a detailed, slide-by-slide summary—translated into English and focused on the key takeaways you’ll need for your lessons.

1. Motivation and Role

- **Business Need:** Almost every organization needs Internet connectivity—and an Internet-connected host is a potential attack target. Downtime or breaches cost money directly (lost sales) and indirectly (reputation, recovery).
- **Firewall Purpose:** A firewall is the *physical embodiment* of your network security policy. It sits between two networks (usually the Internet and your private LAN), controlling and monitoring all traffic and enforcing *who* (which host), *when*, *what*, and *how* resources can be accessed.

2. Core Requirements

1. **All traffic**—inbound and outbound—must pass through the firewall (no “back doors”).
2. **Only authorized traffic**—as defined by your security policy—may traverse the firewall.
3. **Firewall hardening:** the firewall itself must be secured (“no extra services”), running on dedicated, trust-hardened hardware or hardened OS installs.

3. Terminology & DMZ

- **Packet/Datagram:** the basic unit of information in TCP/IP.
- **DMZ (Demilitarized Zone):** a network segment between the untrusted Internet and your protected LAN, hosting public services (web, mail, etc.) and application gateways.
- **Protected vs. Unprotected Networks:** the firewall protects the “inside”; the Internet lies outside.
- **Traffic Directions:** “Inbound” = into the protected zone; “Outbound” = out to the Internet.

4. Access Control Parameters

Firewalls can enforce rules at multiple layers:

- **Data-link (Layer 2):** e.g., drop all frames from a specific MAC, allow only certain MACs without authentication.
- **Network (Layer 3):** e.g., block all except 10.10.10.0/24→any, allow only IPsec ESP, permit 172.16.30.0/24→192.168.10.0/24.
- **Transport (Layer 4):** e.g., allow HTTP to 192.168.0.10 only, FTP to 192.168.0.11 only.
- **Application (Layer 7):** e.g., block P2P, disallow HTTP “POST” in headers, block SMTP “DEBUG” commands.

5. Firewall Types

1. **Packet-Filtering Firewall** (stateless): inspects only IP/port headers, no payload inspection or context; very fast and simple, but limited against protocol vulnerabilities and fragmentation.
2. **Stateful Inspection Firewall:** builds a dynamic “state table” per connection (TCP, UDP), tracking sequence numbers, ports and allowing only context-valid packets; high performance and the most popular.
3. **Application Firewall / Deep Packet Inspection:** filters by application-level commands (e.g., block executables in email, ActiveX content in web pages, FTP “PUT”); specialized per protocol (HTTP, SQL, SMTP).
4. **Proxy Gateway (Application-Level Gateway):** the client and server each speak only to the proxy; the proxy enforces policy, hides internal IPs, and can even inspect SSL. Requires a separate proxy per service.
5. **Personal Firewall:** host-based, simplified firewall for workstations; blocks unauthorized inbound connections, inspects in/out traffic, often centrally managed for organizational policy.

6. Emerging “Firewall” Tech

- **NAC/NAP:** Network Access Control places new hosts into a quarantine VLAN, checks patch/antivirus status, then grants full access once compliant.

- **UTM (Unified Threat Management):** converged appliance offering firewall, IPS, antivirus, VPN, DLP, etc., in one box—easier admin but potential performance limits.
- **Virtualization Firewalls:** network-level firewalls for virtual machines, policing traffic between VMs on the same host.

7. Implementation Options

- **Appliance vs. Software:** dedicated OS vs. general-purpose OS; trade-offs of performance, cost, ease of integration.
- **Key Features:** throughput (bps, pps, conn/s), scalability (ASIC vs. CPU), policy granularity (addresses, applications, user identity), high availability (active/active, active/passive), integration (RADIUS/TACACS+, syslog), management interfaces (SSH, HTTPS).

8. Limitations and Market

- **Limitations:** cannot stop insider threats, cannot inspect encrypted/tunneled traffic, do not block email/web malware, complex to configure.
- **Product Examples:** Cisco ASA, Check Point, Juniper NetScreen, Palo Alto, FortiGate, McAfee, Stonesoft, Linux iptables.
- **Market Positioning:** Gartner's Magic Quadrant illustrates vendor strengths and trends toward integrated IDS/IPS within firewalls.

2: IDS (RO).pdf 2. IDS (RO) 2. IDS (RO)

Below is a structured, English-language summary of the “IDS/IPS” lesson, highlighting the most important concepts and terminology:

1. Core Definitions

- **Intrusion:** A set of actions aimed at compromising the security of a computer or network.
 - **Intrusion Detection:** The process of identifying and responding to such intrusions.
 - **IDS (Intrusion Detection System):** Tools and methods that help detect, evaluate, and report intrusions—analogue to physical-security sensors such as cameras or motion detectors 2. IDS (RO).
-

2. Why Use an IDS?

- Acts as the **second line of defense** after a firewall (defense-in-depth), catching attacks that firewalls alone cannot stop (e.g., CodeRed, Nimda) 2. IDS (RO).
 - **Visibility:** Provides continuous insight into ongoing attacks against the organization.
 - **Effectiveness Measurement:** Gauges how well existing security controls are working.
 - **Forensics & Accountability:** Supplies the evidence needed to trace and hold attackers responsible.
-

3. Terminology

- **False Positive:** Legitimate activity flagged as an attack.
- **False Negative:** Malicious activity that goes undetected.

- **“Low and Slow” Attack:** Stealthy attacks that evade threshold-based detection by moving slowly over time.
 - **“In the Wild” vs. “In the Zoo”:** Live (real-world) vs. controlled (lab) attack code scenarios 2. IDS (RO).
-

4. IDS Architecture & Deployment Models

- **By Placement:**
 - **NIDS (Network-based IDS):** Monitors network traffic via promiscuous-mode sensors, often using SPAN/mirror ports on switches 2. IDS (RO).
 - **HIDS (Host-based IDS):** Installed on individual systems, monitoring system logs, running processes, and file-integrity events 2. IDS (RO).
 - **Application-level IDS:** A subclass of HIDS focused on a single application’s events.
 - **By Detection Method:**
 - **Signature-based:** Maintains a database of known attack “fingerprints.” Offers low false-positive rates and detailed attack info, but cannot detect novel threats and slows down as signatures grow 2. IDS (RO).
 - **Anomaly-based:** Builds a “normal behavior” profile (learning mode) then flags deviations (detection mode). Can catch zero-days and “low and slow” attacks, but generates more false positives and generic alerts 2. IDS (RO).
 - **By Response Mode:**
 - **Passive IDS:** Alerts and logs only (e.g., SNMP traps).
 - **Active IDS / IPS:** Takes automated action (TCP resets, ACL updates, additional data collection).
-

5. NIDS vs. HIDS Advantages & Limitations

- **NIDS:**
 - **Pros:** High scalability (a few sensors cover large networks), zero impact on monitored hosts, OS-agnostic, can run stealthily.
 - **Cons:** Cannot see encrypted traffic (VPN/SSL), may miss packets at high throughput, blind to insider/host events 2. IDS (RO).
 - **HIDS:**
 - **Pros:** Detects host-local threats (trojans, rootkits), works despite encryption, no extra network hardware.
 - **Cons:** Scalability challenges (agent rollout), performance overhead on hosts, vulnerable if host is compromised, blind to network-level scans/DoS 2. IDS (RO).
-

6. Signature-Based IDS

- **How It Works:** Compares traffic/events against a library of known attack signatures (e.g., the “land” attack where source=destination IP).
 - **Management:** Requires frequent signature updates (“knowledge-based” approach).
 - **Trade-Off:** Precise alerts and low false positives versus inability to detect unknown attack types 2. IDS (RO).
-

7. Anomaly-Based IDS

- **Learning Phase:** Builds statistical/behavioral profiles (e.g., who/when/where logs in, average CPU load).
- **Detection Phase:** Flags deviations beyond configured thresholds. Protocol anomalies (90% of attacks exploit protocol misuse) and traffic-pattern anomalies are key focus areas.
- **Trade-Off:** Detects novel and stealthy attacks but suffers a higher false-positive rate and requires expert tuning 2. IDS (RO).

8. Attack Response

- **Passive:** Generate alarms, notifications, SNMP traps.
- **Active (IPS style):** Inject TCP resets, dynamically modify firewall/ACL policies, gather extra attacker info.

9. From IDS to IPS & Key Features

- **IDS vs. IPS:** IPS sits inline (active blocking), while IDS is out-of-band (passive monitoring).
- **Key Criteria:**
 - **Sensor Coverage & Throughput**
 - **Detection Accuracy** (false positives/negatives)
 - **Modularity** (plugin/script support)
 - **Logging** (local vs. centralized)
 - **Management** (role separation, central console)
- **Common Products:** Snort/Sourcefire, Cisco/Juniper IPS, TippingPoint, McAfee, Stonesoft, Radware NBAD

3: LANSec (RO).pdf 3. LANSec (RO) 3. LANSec (RO)

Below is an English-language summary of the LAN-level security lesson, capturing its most important concepts and countermeasures:

1. Why LAN Security Matters

- **Ubiquitous Open Ports:** In most organizations, virtually every network jack is live by default—anyone with a laptop can plug in and access the LAN.
 - **Insider Threats:** Up to 60 % of attacks originate from inside the organization, making perimeter defenses alone insufficient.
 - **Common LAN Attacks:** Traffic sniffing, DHCP starvation, rogue DHCP servers, ARP poisoning, MAC table attacks (flooding/stealing) 3. LANSec (RO).
-

2. Traffic Sniffing

- **Passive Sniffing** (Hubs): In a hub-based network, a sniffer in promiscuous mode captures **all** traffic without altering the network—completely stealthy.
 - **Active Sniffing** (Switches): Switches forward frames only to the port matching the destination MAC, so attackers must manipulate the network (e.g., MAC flooding or port stealing) to force switches to broadcast or remap traffic 3. LANSec (RO).
 - **Tools:**
 - **tcpdump/WinDump** for command-line captures
 - **Wireshark (formerly Ethereal)** for GUI-based analysis
 - **ngrep, SniffIt, pcap libraries** for custom packet capture 3. LANSec (RO).
-

3. MAC-Table Attacks

- **MAC Flooding:** Attackers overwhelm a switch's finite CAM (MAC) table by sending frames with random source MACs. Once the table is full, the switch "fails open,"

broadcasting all subsequent frames out every port—allowing sniffing 3. LANSec (RO).

- **Port Stealing:** By spoofing the victim's MAC as the source on frames sent to the switch, the attacker poisons the MAC table entry so that traffic destined for the victim is redirected to the attacker's port 3. LANSec (RO).
 - **Countermeasures:**
 - **Port Security:** Limit the number of MAC addresses learned per port and shut down or quarantine ports exceeding that limit.
 - **CAM Table Hardening:** Increase table size or enable features to drop flood sequences and alert administrators.
-

4. DHCP Attacks

- **DHCP Starvation:** The attacker exhausts all available IP leases by repeatedly requesting addresses with spoofed MACs, causing a denial-of-service for legitimate hosts.
 - **Rogue DHCP Server:** An unauthorized server advertises itself on the LAN and hands out malicious network parameters (e.g., setting itself as gateway or DNS), enabling MITM or DoS.
 - **Countermeasures:**
 - **Port Security:** As above, limits how many leases an attacker can obtain per switch port.
 - **DHCP Snooping:** Switches mark all access ports as “untrusted” by default; only designated “trusted” ports (where legitimate DHCP servers reside) may forward DHCP replies. The switch builds a binding table of valid leases and drops any DHCP traffic from untrusted ports 3. LANSec (RO).
-

5. ARP Poisoning

- **ARP Protocol:** Hosts broadcast ARP requests to map IP→MAC; responses are cached in each host's ARP table.

- **Poisoning Technique:** Attackers send unsolicited (gratuitous) ARP replies claiming ownership of another IP, altering ARP caches on targets and routers to redirect traffic through the attacker 3. LANSec (RO).
- **Countermeasures:**
 - **Static ARP Entries:** Manually bind critical IP→MAC mappings on sensitive hosts.
 - **Network Monitoring:** Tools like **arpwatch** detect unexpected ARP updates.
 - **Dynamic ARP Inspection (DAI):** Switches validate ARP replies against the DHCP snooping binding table, discarding unauthorized updates.
 - **Secure-ARP:** Use cryptographic methods (e.g., certificates) to authenticate ARP messages.

4: SecTools (RO).pdf 4. SecTools (RO) 4. SecTools (RO) 4. SecTools (RO) 4. SecTools (RO) 4. SecTools (RO)

Below is an English-language, detailed summary of the key lessons from the “Security Tools” presentation:

1. Categories of Security Tools

1. **Port Scanners** – Identify active hosts and open ports/services on a network; form the basis of network mapping 4. SecTools (RO).
 2. **Vulnerability Scanners** – Automate discovery and reporting of known vulnerabilities in systems and applications 4. SecTools (RO).
 3. **File Integrity Checkers** – Monitor critical files for unauthorized changes by periodically computing and comparing cryptographic checksums; often packaged as host-based IDS agents (e.g., Tripwire, AIDE, Afick) 4. SecTools (RO).
 4. **Other Tools** – Banner grabbers, OS fingerprinters, fuzz testers, reverse-engineering utilities.
-

2. Port Scanning Techniques

- **ICMP Ping** – Basic reachability test using ECHO_REQUEST/REPLY; easily filtered by firewalls 4. SecTools (RO).
- **ARP Ping** – Discovers local-segment hosts via ARP requests; bypasses IP-level filters but fails if proxy ARP is in use 4. SecTools (RO).
- **TCP Connect() Scan** – Fully opens TCP connections (connect()); reliable but easily logged 4. SecTools (RO).
- **TCP SYN (“Half-Open”) Scan** – Sends SYN, awaits SYN-ACK, then resets; stealthier and faster since no full connection is established 4. SecTools (RO).
- **Stealth Scans (FIN, Xmas Tree, Null)** – Craft packets with unusual flag combinations; exploit RFC 793 behavior to infer port states while evading simple IDS signatures 4.

SecTools (RO).

- **UDP Scan** – Sends UDP probes; lack of ICMP Port Unreachable implies an open port, but suffers from slow response times (1–4 s per probe) 4. SecTools (RO).
-

3. OS Fingerprinting

- **Passive Fingerprinting** (e.g., p0f) – Observes live traffic and infers OS from subtle stack-implementation differences (TTL, window size, flags); completely stealthy but lower accuracy 4. SecTools (RO).
 - **Active Fingerprinting** (e.g., `nmap -O`) – Sends a series of crafted probes (TCP, UDP, ICMP) and analyzes responses for OS signatures; higher accuracy but more detectable 4. SecTools (RO).
-

4. Banner Grabbing

- **Interactive Tools** – `telnet <host> 80`, `amap`, `httpprint` to manually elicit service banners.
 - **Automated Version Detection** – `nmap -sV` probes services and parses returned banners to determine exact version numbers 4. SecTools (RO).
-

5. Vulnerability Discovery & Management

- **Vulnerability**: A programming bug or misconfiguration that an attacker can exploit.
- **Discovery Techniques**:
 - **Source Code Analysis** – Manual or automated review of code.
 - **Fuzz Testing** – Supplying random/invalid inputs to trigger unexpected behaviors.

- **Reverse Engineering** – Disassembling binaries to uncover hidden flaws 4. SecTools (RO).
 - **Vulnerability Databases:**
 - **CVE** (Common Vulnerabilities and Exposures) standardizes names.
 - **NVD, Secunia, OSVDB, SecurityFocus** provide searchable databases 4. SecTools (RO).
-

6. Vulnerability Scanners

- **Classification:**
 1. **Location:** Network-based vs. host-based.
 2. **Credentials:** Authenticated (with administrative rights) vs. unauthenticated.
 3. **Target Type:** General systems, web applications, databases.
 - **Popular Products:** Nessus, OpenVAS, Microsoft MBSA, Core Impact, IBM Internet Scanner, GFI LANGuard, Retina, QualysGuard, etc. 4. SecTools (RO).
 - **Nessus Deep Dive:**
 1. **Architecture:** Client/UI + scanning server (engine) over SSL.
 2. **Plugin Model:** ~40 000 NASL scripts, modular and updatable.
 3. **Service Detection:** Port scanning (ping, TCP connect, SYN).
 4. **Scan Modes:** Safe vs. destructive.
 5. **Reporting:** HTML outputs, CVE compatibility, tiered subscriptions (Professional vs. free HomeFeed) 4. SecTools (RO).
-

7. File Integrity Checkers

- **Purpose:** Detect unauthorized changes to critical system files.
- **Mechanism:** Compute cryptographic hashes periodically and compare against a trusted baseline.
- **Examples:**
 - **Tripwire** (Unix/Windows)
 - **AIDE**
 - **Afick**